**Phase 1 Reflection Project**
Omoze Idehenre
4/25/2026
PKI Foundations

# Part 1: The Phase 1 Journey

At the start of Phase 1, I thought PKI was mainly about “SSL certificates” and encryption. I understood that it made websites secure, but I didn’t understand how trust was actually established or enforced.

In Week 1, I learned that PKI is fundamentally about identity and trust. The concept of a trust chain was the first thing that genuinely challenged me. It was surprising to realize that trust is not built directly between systems, but through a hierarchy of Certificate Authorities (CAs) that validate and vouch for identities.

In Week 2, I started working directly with the command line using OpenSSL. This was the moment everything began to connect. My understanding deepened into the mechanics behind that trust. I learned that confidentiality, integrity, and authenticity are separate problems solved by different cryptographic techniques. This changed how I think about security. Not as one control, but as multiple layers working together.

By Week 3, I moved further from abstract concepts to actually retrieving, parsing, and validating certificates in real environments.

Weeks 4 through 6 were the biggest shift. I stopped just learning PKI and started troubleshooting it. Diagnosing expired certificates, broken chains, and SAN mismatches helped me understand how PKI fails in real systems, not just how it works when everything is correct.

By Week 7, I began thinking about PKI at an enterprise level. I learned how infrastructure like CDNs and load balancers handle TLS and how certificates are managed at scale.

My understanding evolved from:
“PKI is encryption.” → “PKI is a system that enforces identity, trust, and secure communication across infrastructure.”

---

# Part 2: How the Pieces Connect

PKI operates as a complete system, not isolated concepts.

It begins with **cryptographic foundations**:

- Symmetric encryption protects data efficiently
- Asymmetric cryptography enables identity and key exchange
- Hashing ensures integrity
- Digital signatures provide authenticity

These components are combined into **X.509 certificates**, which act as digital identity documents.

Each certificate contains:

- A subject (identity)
- An issuer (who signed it)
- A public key
- A validity period
- Extensions like SAN that define usage

Certificates are validated through a **trust chain**:

- Leaf certificate (the server)
- Intermediate CA (delegated trust)
- Root CA (trusted authority)

If any part of the chain is missing or invalid, trust fails.

This system operates across a **lifecycle**:

- Key generation
- CSR creation
- Certificate issuance
- Deployment
- Validation
- Expiration or revocation

Troubleshooting happens when something in this lifecycle breaks:

- Expired certificate → validity failure
- Missing intermediate → chain failure
- SAN mismatch → identity failure

In real-world deployment (like HTTPS):

- PKI verifies identity
- TLS encrypts communication
- Browsers enforce trust using root stores

This is how secure communication actually works in modern systems.

---

## Part 3: A Lab That Made It Real

**Lab referenced:**
labs/week-06/submissions/02-broken-chain/lab-02-broken-chain.md

This lab made PKI real for me because it showed that a certificate can be valid but still fail due to a missing trust chain.

When I first validated the chain command, I used the command:

```
openssl verify leaf_cert.pem
```

I saw:

```
error 20 at 0 depth lookup: unable to get local issuer certificate leaf_cert.pem
```

This indicated that the chain was broken and that the intermediate certificate was missing.

After adding the intermediate to repair the issue, I validated using this command:

```
openssl verify -untrusted issuer_cert.pem leaf_cert.pem
```

The result changed to:

```
leaf_cert.pem: OK
```

This taught me that trust is not just about the certificate itself; it depends on the full chain being present and correctly delivered.

---

## Part 4: Explaining PKI to Someone Who Doesn't Know It

The biggest misconception is thinking PKI is just about encryption. Encryption protects your data, but PKI answers a more important question:
**"Who am I actually talking to?"**

PKI is a system of digital identity. When you visit a website, it presents a certificate like an ID card. Your browser checks if that ID was issued by someone it trusts. If it is, the connection continues securely. If not, you get a warning.

Without PKI, encryption could still happen, but you wouldn't know if you were talking to the real system or an attacker.

---

## Part 5: Where You Go From Here

Week 7 showed me how PKI operates in enterprise environments. I learned that TLS often terminates at infrastructure layers like CDNs, not directly on application servers.

A second lab that reinforced this was:

**Lab referenced:**
labs/week-06/submissions/03-san-mismatch/lab-03-san-mismatch.md

This lab showed that even when a certificate is valid, it can fail if the hostname does not match the SAN entries. This reinforced that identity validation is strict and separate from trust chain validation.

Going forward, I am interested in:

- Cloud security and infrastructure security roles
- Certificate lifecycle automation (ACME, AWS Certificate Manager)
- TLS handshake internals
- Enterprise PKI design and governance

The most relevant part of Phase 1 for my goals was troubleshooting and real-world analysis. It helped me move from theoretical understanding to practical security thinking.

---

# Required Visual: A Complete Certificate Lifecycle From Key Generation Through Revocation

**Visual file:**
reflections/visual/phase1-diagram.png

**Description:**

Welcome to the PKI universe, where trust isn't just given, it's earned, verified, and constantly monitored like a high-security galactic system.

The journey starts at the **Key Forge,** where a powerful private key is created and locked away like a sacred artifact, while its twin, the public key, is released into the galaxy for others to see. Together, they form the foundation of secure communication.

Next, a **Certificate Signing Request (CSR)** is launched like a transmission across space, carrying identity details and the public key to the **Certificate Authority (CA)**, the ultimate galactic gatekeeper. The CA doesn't just trust anyone; it performs identity checks before approving.

Once verified, the CA issues a signed certificate, basically your system's official galactic ID badge. Now you're recognized and trusted across the network.

From there, the certificate is deployed to a server, preparing it for real-world interactions. When a user connects, the TLS handshake kicks off. Think of it like a spaceship docking sequence. The system checks the full certificate chain (Root → Intermediate → Leaf) to make sure everything is legit. If all checks out? Boom, secure communication established. But here's the twist: trust is never permanent.

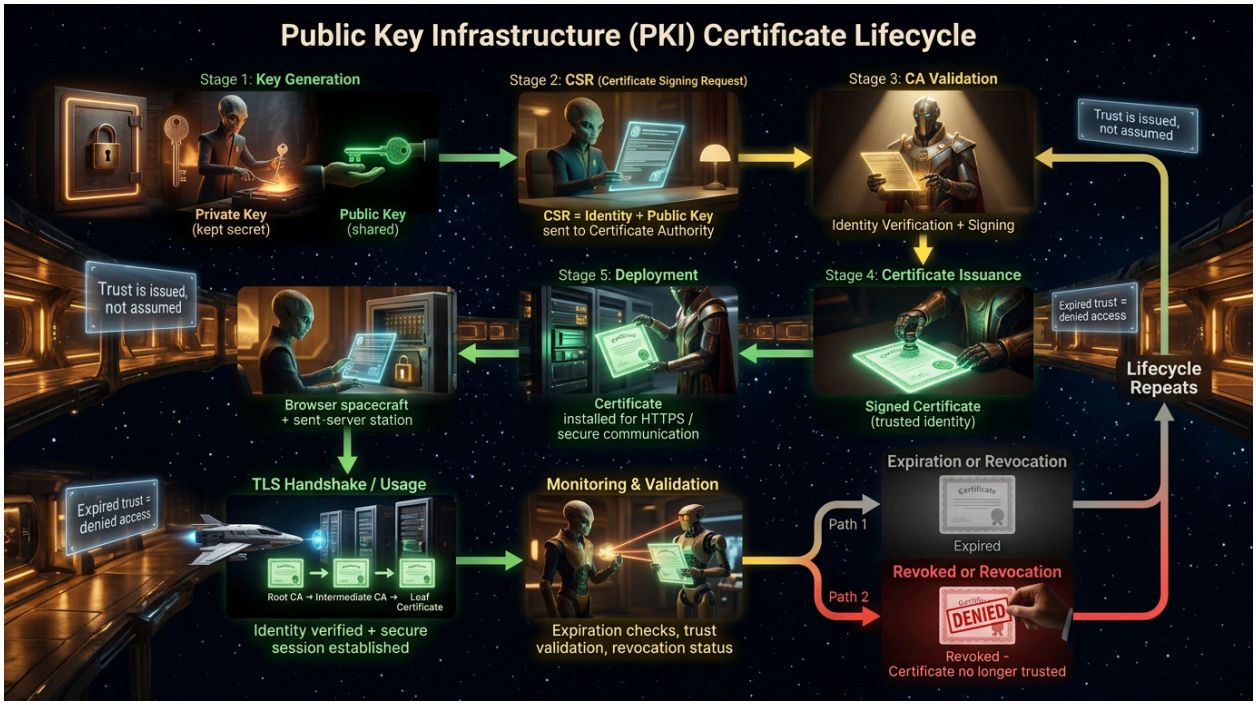
Behind the scenes, systems are constantly running monitoring and validation checks, watching for expiration, revocation, or anything suspicious. Because in this galaxy, trust must be maintained, not assumed.

Eventually, every certificate reaches its fate:

- Expiration → your ID badge simply runs out of time
- Revocation → access is instantly denied  (you've been flagged)

Either way, trust is lost, and access is shut down. Then? The cycle begins again.

Because PKI isn't static, it's a living, breathing galaxy of identity, security, and continuous verification, keeping every connection safe across the universe.


Public Key Infrastructure (PKI) Certificate Lifecycle
Stage 1: Key Generation
Private Key
(kept secret)
Public Key
(shared)
Stage 2: CSR (Certificate Signing Request)
CSR = Identity + Public Key
sent to Certificate Authority
Stage 3: CA Validation
Identity Verification + Signing
Trust is issued, not assumed
Stage 4: Certificate Issuance
Signed Certificate
(trusted identity)
Expired trust = denied access
Stage 5: Deployment
Certificate
installed for HTTPS / secure communication
Trust is issued, not assumed
Browser spacecraft
+ sent-server station
TLS Handshake / Usage
Root CA → Intermediate CA → Leaf Certificate
Identity verified + secure session established
Expired trust = denied access
Monitoring & Validation
Expiration checks, trust validation, revocation status
Path 1
Path 2
Expiration or Revocation
Expired
Revoked or Revocation
DENIED
Revoked - Certificate no longer trusted
Lifecycle Repeats